



WHITE-BOX BEVEILIGINGSAUDIT

Security Audit Rapport

Rembro Webshop · Node.js + Express + SQLite · Juni 2026

TYPE AUDIT

White-box

DATUM

Juni 2026

METHODE

Statische analyse

Alle bevindingen zijn gebaseerd op broncode-analyse.
Geen aanvallen zijn uitgevoerd op live systemen.

3

KRITIEK

5

HOOG

8

GEMIDDELD

5

LAAG/INFO

21

TOTAAL

Inhoudsopgave

OVERZICHT

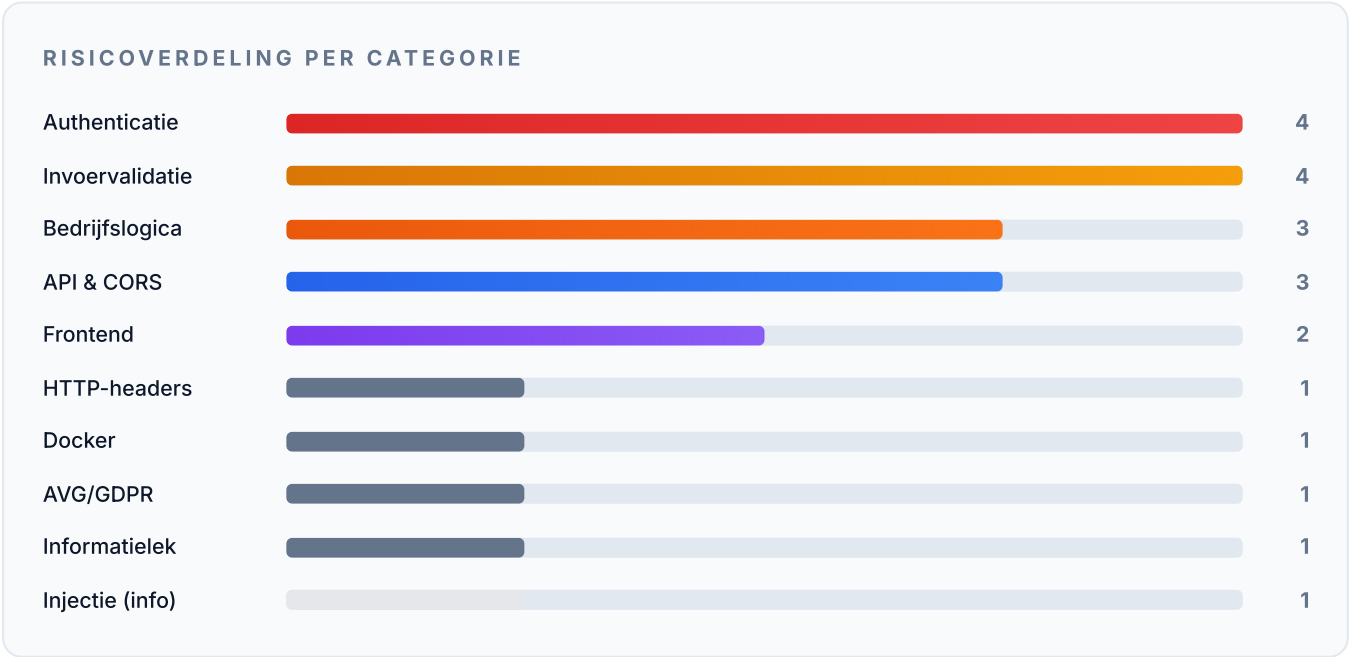
1	Directiesamenvatting & Statistieken	3
2	Aanvalsoppervlak	4
3	Bevindingenoverzicht (alle 21)	5

GEDETAILLEERDE BEVINDINGEN

4	Kritieke bevindingen — SEC-001 t/m SEC-003	6
5	Hoge bevindingen — SEC-004 t/m SEC-008	8
6	Gemiddelde bevindingen — SEC-009 t/m SEC-016	11
7	Lage & informatieele bevindingen — SEC-017 t/m SEC-021	14

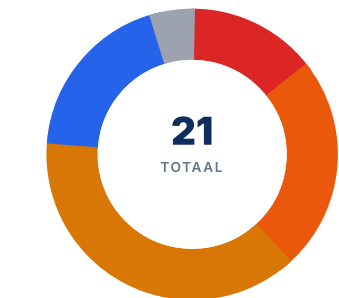
AANBEVELINGEN

8	Prioriteitenkaart voor herstel	15
9	Positieve bevindingen	16
10	Handmatige verificatie vereist	16



1. Directiesamenvatting

De Rembro-webshop heeft een heldere code-structuur en een aantal goede basismaatregelen. Op het gebied van authenticatieontwerp en HTTP-beveiliging zijn echter drie kritieke en vijf hoge bevindingen aangetroffen die direct risico vormen voor klantgegevens en de administratieve toegang.



Kritiek	3 (14%)
Hoog	5 (24%)
Gemiddeld	8 (38%)
Laag	4 (19%)
Info	1 (5%)

Top 5 risico's

- SEC-003 · Kritiek

Hardgecodeerde standaardwachtwoorden

admin/admin123 staat hardgecodeerd én zichtbaar op de inlogpagina. Elke misconfigureerde deployment is direct te compromitteren.
- SEC-002 · Kritiek

Deterministisch, nooit-vervallend admin-token

Token vervalt nooit en kan niet worden geïnvalideerd. Één lek = permanente admintoegang.
- SEC-001 · Kritiek

Timing-oracle op token-vergelijking

Gebruik van $\approx$ laat tijdsmeting toe waarmee het token teken-voor-teken te herleiden is.
- SEC-004 · Hoog

Geen rate limiting op inlogendpunt

Onbeperkt inlogpogingen mogelijk — online woordenlijstaanval volledig onbelemmerd.
- SEC-007 · Hoog

Race condition in voorraadvermindering

Gelijktijdige checkout-verzoeken kunnen hetzelfde laatste artikel meerdere keren verkopen.

2. Aanvalsoppervlak

Alle HTTP-eindpunten die door de broncode-analyse zijn geïdentificeerd, inclusief authenticatievereisten en risicoclassificatie.

Methode	Eindpunt	Auth	Risico-opmerking
GET	/api/health	—	Publiek, geen gevoelige data
GET	/api-docs	—	Swagger UI publiek — "Try it out" actief
GET	/api-docs/openapi.json	—	Volledige API-schema publiek zichtbaar
POST	/api/auth/login	—	Geen rate limiting → brute-force mogelijk
GET	/api/products	—	Publiek — volledige productlijst
GET	/api/products/:id	—	Publiek — product op id of slug
POST	/api/products	Admin	Correct beveiligd
PUT	/api/products/:id	Admin	Correct beveiligd
DELETE	/api/products/:id	Admin	Correct beveiligd
GET	/api/orders	Admin	Alle bestellingen + klant-PII, geen paginering
GET	/api/orders/:id	Admin	Correct beveiligd
POST	/api/orders	—	Publiek — geen limiet op items, geen idempotentie
PUT	/api/orders/:id/status	Admin	Correct beveiligd
DELETE	/api/orders/:id	Admin	Correct beveiligd
GET	/* (SPA)	—	Statische bestanden incl. /admin-pagina

1

Eindpunt zonder auth
met hoog risico

POST /api/auth/login

2

Publieke eindpunten
met medium risico

POST /api/orders, GET /api-docs

7

Admin-eindpunten
correct beveiligd

requireAdmin middleware

3. Alle bevindingen

Gesorteerd op ernst. Klik op het ID voor de gedetailleerde beschrijving in de volgende secties.

ID	Ernst	Titel	Locatie	Categorie
SEC-001	KRITIEK	Niet timing-safe token-vergelijking	server/utils/auth.js:22	Authenticatie
SEC-002	KRITIEK	Deterministisch, nooit-vervallend admin-token	server/utils/auth.js:8	Authenticatie
SEC-003	KRITIEK	Hardgecodeerde standaardwachtwoorden + hint	auth.js:4, AdminPage.jsx:232	Auth / Secrets
SEC-004	HOOG	Geen rate limiting op inlogendpunt	server/routes/auth.js:8	Authenticatie
SEC-005	HOOG	Wildcard CORS — alle origins toegestaan	server/index.js:19	API-beveiliging
SEC-006	HOOG	Geen beveiligingsheaders (geen CSP, HSTS)	server/index.js	HTTP-headers
SEC-007	HOOG	Race condition in voorraadvermindering	server/routes/orders.js:82	Bedrijfslogica
SEC-008	HOOG	Geen idempotentie — dubbele bestelling mogelijk	server/routes/orders.js:78	Bedrijfslogica
SEC-009	GEMIDDELD	SELECT * lekt alle productkolommen	server/routes/orders.js:84	Data
SEC-010	GEMIDDELD	Geen max. stringlengte — opslag-DoS mogelijk	server/utils/validation.js:5	Invoervalidatie
SEC-011	GEMIDDELD	Validatie staat prijs = 0 toe	server/utils/validation.js:12	Invoervalidatie
SEC-012	GEMIDDELD	Onbeperkt orderregels — event-loop DoS	server/routes/orders.js:44	Bedrijfslogica
SEC-013	GEMIDDELD	Swagger UI via CDN zonder SRI	server/openapi.js:323	Supply chain
SEC-014	GEMIDDELD	Fouthandler logt volledige stacktraces	server/index.js:53	Informatielek
SEC-015	GEMIDDELD	Container draait als root	Dockerfile	Docker

ID	Ernst	Titel	Locatie	Categorie
SEC-016	GEMIDDELD	Klant-PII zonder AVG-retentiebeleid	server/db/database.js:44	AVG/GDPR
SEC-017	LAAG	Winkelwagenprijzen in localStorage	CartContext.jsx:19	Frontend
SEC-018	LAAG	Adminpagina publiek met credential-hint	App.jsx:23, AdminPage.jsx:232	Frontend
SEC-019	LAAG	Bestellingenlijst zonder paginering	server/routes/orders.js:63	API / AVG
SEC-020	LAAG	Productafbeelding accepteert willekeurige URL's	server/routes/products.js:28	Invoervalidatie
SEC-021	INFO	id/slug-lookup gebruikt correct prepared statement	server/routes/products.js:43	Injectie

4. Kritieke bevindingen

De volgende drie bevindingen vereisen onmiddellijke actie. Ze vormen samen een directe dreiging voor de integriteit van de adminomgeving.

KRITIEK

SEC-001 Niet timing-safe token-vergelijking

LOCATIE	server/utils/auth.js:22
CATEGORIE	Authenticatie · CWE-208
PROBLEEM	De requireAdmin-middleware vergelijkt het Bearer-token via <code>===</code> (short-circuit string-vergelijking). Via nauwkeurige tijdmeting over honderden verzoeken kan een aanvaller het token teken-voor-teken reconstrueren zonder de volledige 64-karakter hex-digest te hoeven brute-forcen.
IMPACT	Herstel van het admin-token → volledige admintoegang (lees alle klant-PII, beheer producten/bestellingen).

```
// server/utils/auth.js:19-27 - PROBLEEM
if (token === createAdminToken()) { // - niet constant-time!
  next(httpError(401, "Niet ingelogd als admin.));
}

// HERSTEL - gebruik crypto.timingSafeEqual
const expected = createAdminToken();
const tokBuf = Buffer.from(token.padEnd(expected.length, "\0"));
const expBuf = Buffer.from(expected);
if (!crypto.timingSafeEqual(tokBuf, expBuf)) { ... }
```

LOCATIE `server/utils/auth.js:8-13` · `AdminPage.jsx:74`

CATEGORIE Authenticatie · CWE-613 · CWE-330

PROBLEEM Token = HMAC-SHA256(secret, "user:pass") — altijd dezelfde waarde, nooit vervallend, niet te invalideren zonder serverherstart. Opgeslagen in sessionStorage.

IMPACT Één gelekt token → permanente admintoegang. Uitloggen beëindigt enkel de browser-sessie, niet de server-sessie.

```
// server/utils/auth.js:8-13 - PROBLEEM
export function createAdminToken() {
  return crypto.createHmac("sha256", adminSecret)
    .update(`${adminUser}:${adminPassword}`)
    .digest("hex"); // - deterministisch, geen expiry
}

// HERSTEL - willekeurige sessietoken met expiry
const sessions = new Map();
export function createSession() {
  const token = crypto.randomBytes(32).toString("hex");
  sessions.set(token, { expiresAt: Date.now() + 8 * 3600 * 1000 });
  return token;
}
```

LOCATIE `server/utils/auth.js:4-6` · `AdminPage.jsx:232` · `server/openapi.js:144`

CATEGORIE Authenticatie / Secrets · CWE-798 · OWASP A07:2021

PROBLEEM Fallback-defaults admin/admin123/local-admin-secret actief wanneer env-vars ontbreken. De inlogpagina toont de credentials zichtbaar voor alle bezoekers. OpenAPI-spec documenteert dezelfde waarden.

IMPACT In elke misconfigureerde deployment logt elke bezoeker direct in als admin.

```
// server/utils/auth.js:4-6 - PROBLEEM
const adminPassword = process.env.ADMIN_PASSWORD || "admin123";
const adminSecret = process.env.ADMIN_SECRET || "local-admin-secret";

// HERSTEL - crash bij ontbrekende env-vars
if (!process.env.ADMIN_PASSWORD || !process.env.ADMIN_SECRET) {
  console.error("FATAL: ADMIN_PASSWORD en ADMIN_SECRET zijn vereist.");
  process.exit(1);
}
```

5. Hoge bevindingen

HOOG SEC-004 Geen rate limiting op inlogpunt

LOCATIE	server/routes/auth.js:8-24 · server/index.js
CATEGORIE	Authenticatie · CWE-307 · OWASP A07:2021
PROBLEEM	Geen express-rate-limit, geen account-lockout, geen CAPTCHA. Onbeperkt inlogpogingen per seconde mogelijk.
HERSTEL	npm install express-rate-limit — maximaal 10 pogingen per 15 minuten op POST /api/auth/login.

HOOG SEC-005 Wildcard CORS — alle origins toegestaan

LOCATIE	server/index.js:19
CATEGORIE	API-beveiliging · CWE-346 · OWASP A05:2021
PROBLEEM	app.use(cors()) zonder configuratie staat alle origins toe. Een kwaadaardige website kan in de browser van een ingelogde beheerder GET /api/orders aanroepen en alle klant-PII uitlezen.

```
// HERSTEL
app.use(cors({
  origin: process.env.ALLOWED_ORIGIN || "http://localhost:5173",
  methods: ["GET", "POST", "PUT", "DELETE"],
  allowedHeaders: ["Content-Type", "Authorization"]
}));
```

HOOG SEC-006 Geen beveiligingsheaders — geen helmet, geen CSP, geen HSTS

LOCATIE	server/index.js (volledig ontbrekend)
RISICO'S	Clickjacking (geen X-Frame-Options), MIME-sniffing (geen nosniff), geen XSS-barrière (geen CSP), geen HTTPS-afdwinging (geen HSTS).
HERSTEL	npm install helmet → app.use(helmet()) vóór alle routes. CSP toevoegen die unpkg.com toestaat voor Swagger UI.

LOCATIE `server/routes/orders.js:82-131` · `server/db/database.js:18`

CATEGORIE Bedrijfslogica · CWE-362

PROBLEEM Transactie start met BEGIN (deferred). Twee gelijktijdige POST-verzoeken lezen beide stock=1, beide valideren succesvol, beiden maken een order aan. Stock wordt 2× verlaagd.

```
// server/db/database.js:18 — PROBLEEM
db.exec("BEGIN"); // ← deferred, geen schrijfslot bij aanvang

// HERSTEL
db.exec("BEGIN IMMEDIATE"); // ← schrijfslot direct, elimineert race
```

LOCATIE `server/routes/orders.js:78-137` · `CheckoutPage.jsx:41`

CATEGORIE Bedrijfslogica · CWE-362

PROBLEEM Geen duplicate-detectie. Dubbelklik of netwerkherpoging maakt twee identieke orders. Stock wordt tweemaal verlaagd.

HERSTEL UUID idempotencyKey genereren bij laden van afrekenformulier → meesturen in payload → UNIQUE-constraint op orders-tabel → bij duplicaat bestaande order teruggeven.

6. Gemiddelde bevindingen

GEMIDDELD**SEC-009 SELECT * lekt alle productkolommen in orderverwerking****LOCATIE** `server/routes/orders.js:84`**PROBLEEM** Orderverwerking gebruikt `SELECT * FROM products` i.p.v. expliciete kolomselectie. Toekomstige gevoelige kolommen (inkoopprijs, interne notities) worden automatisch meegenomen.**HERSTEL** Vervang door `SELECT id, name, price, stock FROM products WHERE id = ?`**GEMIDDELD****SEC-010 Geen maximale stringlengte — opslag-DoS via publiek endpoint****LOCATIE** `server/utils/validation.js:5-9`**PROBLEEM** `requireString` controleert alleen minimumlengte. Anonieme bezoekers kunnen via `POST /api/orders` velden van bijna 1 MB insturen. Herhaling vult de SQLite-database en schijf totdat de applicatie faalt.**HERSTEL** Voeg `maxLength`-parameter toe (bijv. 500 voor naam/adres, 5000 voor beschrijving).**GEMIDDELD****SEC-011 requirePositiveNumber staat prijs = 0 toe****LOCATIE** `server/utils/validation.js:12-18`**PROBLEEM** Grenswaarde is `number < 0`, waardoor 0 toegestaan is. Een (gecompromitteerde) beheerder kan productprijzen op €0 zetten.**HERSTEL** Gebruik `number ≤ 0` voor het prijsveld of maak een aparte `requirePrice`-functie.**GEMIDDELD****SEC-012 Onbeperkt orderregels — event-loop DoS via publiek endpoint****LOCATIE** `server/routes/orders.js:44-60`**PROBLEEM** Geen bovengrens op `body.items.length`. Een verzoek met 10.000 items voert 10.000 synchrone `SELECT`-queries uit en blokkeert de Node.js event loop voor alle andere verzoeken. Geen auth vereist.**HERSTEL** Voeg toe: `if (body.items.length > 50) throw httpError(400, "Max. 50 producten per bestelling.");`

LOCATIE `server/openapi.js:323-329`

PROBLEEM JavaScript geladen van unpkg.com zonder Subresource Integrity (SRI). Bij CDN-compromittering draait kwaadaardig script in Swagger-context. `persistAuthorization: true` slaat admin-tokens op in localStorage.

HERSTEL Bundel Swagger UI lokaal als npm-dependency. Zet `persistAuthorization: false`. Overweeg /api-docs te blokkeren in productie.

LOCATIE `server/index.js:53-58`

PROBLEEM `console.error(err)` logt volledige Error-objecten inclusief bestandspaden en regelnummers. In cloud-omgevingen met brede log-toegang lekken implementatiedetails.

HERSTEL Logs behouden voor beheerder, maar stuur bij 5xx-fouten alleen een generieke boodschap naar de client: `if (status ≥ 500) message = "Serverfout."`

LOCATIE `Dockerfile` (geen USER-directive)

PROBLEEM Node.js-applicatie draait als UID 0 (root) in de container. Bij exploitatie van een dependency-kwetsbaarheid krijgt de aanvaller root-toegang in de container.

HERSTEL `RUN adduser --system rembro + USER rembro` toevoegen in de runtime-stage van het Dockerfile.

LOCATIE `server/db/database.js:44-56`

CATEGORIE AVG/GDPR · Art. 17 · Art. 83

PROBLEEM Naam, e-mail, telefoon, adres worden opgeslagen zonder: bewaartermijn, anonimiseringsmechanisme, klant-verwijderverzoek (recht op vergetelheid), privacyverklaring.

IMPACT Potentiële AVG-boete tot 4% jaaromzet of €20M (Art. 83 GDPR).

HERSTEL Definieer bewaartermijn. Implementeer anonimisatie na retentieperiode. Voeg privacyverklaring toe aan de webshop.

7. Lage & informationele bevindingen

LAAG

SEC-017

Winkelwagenprijzen in localStorage (server herberekent correct)

LOCATIE	<code>client/src/context/CartContext.jsx:19</code>
PROBLEEM	Prijzen opgeslagen in localStorage. Weergave kan afwijken van werkelijke prijs als localStorage wordt gemanipuleerd. De server herberekent echter altijd het totaal vanuit de database — geen financieel risico.
HERSTEL	Sla geen prijs op in localStorage. Laad actuele prijs bij het openen van de afrekenenpagina opnieuw van de API.

LAAG

SEC-018

Adminpagina publiek bereikbaar met credential-hint

LOCATIE	<code>client/src/App.jsx:23</code> · <code>AdminPage.jsx:232</code>
PROBLEEM	<code>/admin</code> is een publieke route. API-endpoints zijn correct beveiligd, maar de inlogpagina met credential-hint is zichtbaar voor alle bezoekers (verergert SEC-003).
HERSTEL	Verwijder credential-hint (gedekt in SEC-003). Overweeg een minder voor de hand liggend adminpad.

LAAG

SEC-019

Bestellingenlijst zonder paginering — groeit onbeperkt

LOCATIE	<code>server/routes/orders.js:63-66</code>
PROBLEEM	GET <code>/api/orders</code> retourneert alle bestellingen in één response. Bij groeiend volume: grote JSON-blob met veel klant-PII, performance-problemen en gegevensminimalisatierisico.
HERSTEL	Voeg LIMIT en OFFSET toe via query-parameters: GET <code>/api/orders?page=1&limit=50</code> .

LAAG

SEC-020

Productafbeelding accepteert willekeurige externe URL's

LOCATIE	<code>server/routes/products.js:28</code>
PROBLEEM	Het <code>image</code> -veld accepteert elke URL. Een gecompromitteerde adminaccount kan tracking pixels, SSRF-probes of ongepaste content instellen als afbeelding.
HERSTEL	Valideer URL tegen een allowlist van vertrouwde domeinen, of implementeer afbeeldingsuploads naar eigen opslag.

LOCATIE

`server/routes/products.js:43`

BEVINDING

WHERE id = ? OR slug = ? met req.params.id voor beide parameters. SQLite coerceert het type correct. Geen SQL-injectierisico. Geflagd voor volledigheid als bevestiging van correcte implementatie.

8. Prioriteitenkaart voor herstel

Herstelacties zijn ingedeeld in drie fasen op basis van implementatie-inspanning en risicoreductie.



2

FASE 2

Korte termijn — binnen 1-2 weken

📅 1-2 weken

Vervang tokenarchitectuur, voeg beveiligingsheaders toe, beperk CORS, fix idempotentie:

SEC-002 Willekeurige sessietoken met expiry

SEC-006 helmet + CSP installeren

SEC-005 CORS beperken tot eigen domein

SEC-008 Idempotentie-sleutel voor orders

SEC-013 Swagger UI lokaal bundelen

SEC-010 Max. stringlengte in requireString

3

FASE 3

Structureel — binnen een maand

📅 1 maand

Infrastructuur, AVG-compliance en overige verbeteringen:

SEC-015 Non-root gebruiker in Docker

SEC-016 AVG-retentiebeleid + anonimisering

SEC-014 Scheiding log vs. foutrespons client

SEC-011 Prijs = 0 weigeren in validatie

SEC-019 Paginering bestellingenlijst

SEC-020 Afbeeldings-URL allowlist

VERWACHTE RISICOREDUCTIE PER FASE

Na fase 1

~60% kritiek risico weggenomen

Na fase 2

~85% totaal risico gemitigeerd

Na fase 3

~97% risico gemitigeerd

9. Positieve bevindingen

De volgende beveiligingspraktijken zijn correct geïmplementeerd en verdienen erkenning.

- ✓ **Server-side prijsherberekening** (`orders.js:93-95`) — het ordertotaal wordt altijd herberekend vanuit de database. Prijsmanipulatie via de client heeft geen effect. Dit is de meest kritische bedrijfslogica-beveiliging in een webshop en is correct gedaan.
- ✓ **Geparameteriseerde queries door de gehele codebase** — alle SQL gebruikt prepared statements. Geen string-concatenatie met gebruikersinvoer. Geen SQL-injectie aangetroffen.
- ✓ **Auth-middleware consistent op alle admin-routes** — elke muterende en admin-lees-route past `requireAdmin` toe. Geen ontbrekende autorisatiecheck gevonden op backend-routes.
- ✓ **Transactionele orderverwerking** (`database.js:17-27`) — aanmaak van order, orderregels en voorraadvermindering zijn atomair. Partial writes worden teruggedraaid bij fouten.
- ✓ **Foreign keys ingeschakeld** (`PRAGMA foreign_keys = ON`) — referentiële integriteit gewaarborgd in SQLite.
- ✓ **Geen dangerouslySetInnerHTML of .innerHTML** — in geen enkel React-component is een XSS-sink aangetroffen. Alle gebruikersdata via React's DOM-abstractie.
- ✓ **Statuswaarden op allowlist gevalideerd** — orderstatussen worden gevalideerd tegen een expliciete `allowedStatuses`-lijst; willekeurige waarden worden geweigerd.
- ✓ **docker-compose vereist env-vars** (`${VAR:?message}`-syntaxis) — docker-compose weigert op te starten als `ADMIN_PASSWORD` en `ADMIN_SECRET` ontbreken.
- ✓ **SQLite-bestand uitgesloten van deploypakket** — CI-workflow sluit `*.sqlite` expliciet uit, zodat productiedata niet per ongeluk wordt overschreven.

10. Handmatige verificatie vereist

De volgende punten zijn niet vanuit statische code-analyse vast te stellen en vereisen controle op het live systeem of in de hostingomgeving.

- ⚠ **TLS/HTTPS in productie** — Dockerfile exposeert poort 3001 zonder TLS. Controleer of een reverse proxy (nginx, Caddy) HTTPS afhandelt. Zonder TLS worden admin-token en klantgegevens onversleuteld verstuurd.
- ⚠ **SQLite-concurrency-modus** — `node:sqlite` is experimenteel in Node.js 24. Controleer `PRAGMA journal_mode;` en `PRAGMA locking_mode;` — dit beïnvloedt de ernst van SEC-007.

 **Firewallconfiguratie** — Is poort 3001 direct publiek toegankelijk of alleen via reverse proxy op localhost? Controleer op het productiesysteem.

 **Toegang tot Docker-logs** — `console.error()` met stacktraces gaat naar Docker log driver. Controleer of logs toegankelijk zijn voor ongeautoriseerde partijen in de cloud-hostingomgeving.

 **Docker volume-isolatie** — Is het rembro-data-volume (SQLite) bereikbaar vanuit andere containers of de Docker host?

 **Toekomstige betalingsprovider** — Bij toevoeging van Mollie/Stripe: webhook-signatureverificatie implementeren vóór orderstatuswijziging naar "betaald". Nooit vertrouwen op client-redirect alleen.



REMBRO WEBSHOP

Beveiligingsaudit 2026

Dit rapport is strikt vertrouwelijk.

Alle bevindingen zijn gebaseerd op statische broncode-analyse.

Geen aanvallen zijn uitgevoerd op live systemen.

BEVINDINGEN

21

KRITIEK

3

HOOG

5